Northstar IT Security Guide

Sample information-security handbook for RAG practice

About this document

This fictional sample document has ten numbered sections, each beginning on a separate page. Use it to practise PDF loading, chunking, semantic retrieval, and source-page citations in your RAG project.

Important note

The organization and policies are fictional and are for technical practice only. They should not be treated as real company rules.

1. Information Security Overview

Purpose

This guide describes fictional Northstar Digital Services security practices for technical training. It is not a substitute for an organization's real security policy or incident-response procedure.

Core principles

Protect confidentiality, preserve data integrity, and use approved systems for business information. Access should be limited to what a person needs for their role.

Shared responsibility

Employees follow safe practices, managers approve access based on business need, and IT Security maintains controls and investigates incidents.

When in doubt

Do not bypass a security control because a task is urgent. Pause and contact the IT Service Desk or IT Security for an approved solution.

Practical reminder

If the situation is unclear, consult the appropriate policy owner rather than assuming an exception or inventing a rule.

2. Passwords and Authentication

Password change interval

Employees must change company passwords every 90 days under this sample policy. Change a password immediately if compromise is suspected or IT Security instructs you to do so.

Password quality

Use a long, unique password not reused on personal websites. Avoid names, birthdays, company names, common phrases, and predictable sequences. An IT-approved password manager may be used.

Multi-factor authentication

MFA is required for remote access, administrative actions, and supported company applications. Never approve an authentication prompt you did not initiate.

Password sharing

Never share passwords, one-time codes, recovery codes, or authentication approvals. IT staff will not ask for your current password.

Suspected exposure

If a password may have been exposed, change it through the official sign-in page and report the event to IT Security. Use the verified recovery process if locked out.

Practical reminder

If the situation is unclear, consult the appropriate policy owner rather than assuming an exception or inventing a rule.

3. Device Security

Company devices

Perform business work on company-managed devices whenever possible. Devices must use approved operating systems, endpoint protection, encryption, and management settings.

Screen locking

Lock the screen whenever leaving a device unattended. Configure automatic locking according to company standards. Do not leave a logged-in laptop visible in a vehicle or public area.

Updates

Install approved security updates promptly and restart when required. Do not disable endpoint protection, firewall settings, disk encryption, or device-management software.

Lost or stolen devices

Report a lost or stolen laptop, phone, badge, or security token immediately to the IT Service Desk and manager. Provide the last known location and time if known.

Practical reminder

If the situation is unclear, consult the appropriate policy owner rather than assuming an exception or inventing a rule.

4. Phishing and Social Engineering

Warning signs

Be cautious with urgency, unusual sender addresses, unexpected attachments, login links, gift-card requests, and messages asking for passwords or verification codes.

Verify requests

Confirm unusual payment, access, or data-sharing requests using a separate trusted channel. Do not rely only on a phone number or link supplied in a suspicious message.

Reporting

Use the approved email-reporting function or the security-reporting address provided by IT. Do not click links or open attachments merely to investigate them.

If you clicked

Report immediately if you clicked a suspicious link, entered credentials, approved an unexpected MFA prompt, or opened a suspicious file. Prompt reporting helps contain risk.

Practical reminder

If the situation is unclear, consult the appropriate policy owner rather than assuming an exception or inventing a rule.

5. Data Classification and Handling

Public information

Public information is approved for unrestricted external distribution. Ensure public materials are accurate and authorized for release.

Internal information

Internal information is intended for company use. Share it only with colleagues or approved partners who need it, using company-approved tools.

Confidential information

Confidential information includes customer records, employee data, contracts, financial details, source code, credentials, and non-public business plans. Use approved encrypted storage and limit access.

Restricted information

Restricted information requires the strongest available controls and explicit authorization. Examples may include highly sensitive personal data, production secrets, and security keys.

External sharing

Before sharing files externally, verify recipient, business purpose, classification, and approved transfer method. Public links must not be used for confidential or restricted files.

Practical reminder

If the situation is unclear, consult the appropriate policy owner rather than assuming an exception or inventing a rule.

6. Network and Remote Access

Secure connection

Use the approved company VPN when working remotely or when required to access internal systems. Confirm the VPN is active before opening resources that require it.

Public networks

Avoid handling sensitive data on public Wi-Fi. If use is unavoidable and permitted, connect through the approved VPN and avoid untrusted shared computers.

Remote sessions

Do not leave remote sessions unlocked or share a remote-control session with an unapproved person. End sessions when work is complete.

Network restrictions

Do not connect unauthorized routers, access points, or personal network devices to company networks. Report unusual connection prompts to IT.

Practical reminder

If the situation is unclear, consult the appropriate policy owner rather than assuming an exception or inventing a rule.

7. Email, Collaboration, and File Sharing

Approved tools

Use company-approved email, chat, video conferencing, and file-sharing services. Do not use personal email or consumer file-sharing accounts to transfer confidential company data.

Recipient checks

Check recipients and attachments before sending, especially with autocomplete or external addresses. Use approved secure sharing for sensitive files.

Meeting security

For confidential meetings, confirm participants, use access controls where available, and avoid recording without authorization. Do not share meeting links publicly.

Retention

Keep business records in approved systems according to retention requirements. Do not destroy records subject to a legal hold or investigation.

Practical reminder

If the situation is unclear, consult the appropriate policy owner rather than assuming an exception or inventing a rule.

8. Software, AI Tools, and Development

Software installation

Install software only from approved sources and through the authorized process. Do not use unlicensed tools or disable controls to make an application work.

Secrets in code

Never hard-code API keys, passwords, access tokens, or private certificates into source code. Store secrets in approved secret management or protected environment configuration, and exclude local secret files from version control.

AI tools

Use only AI services approved for the data classification involved. Do not paste customer personal data, credentials, confidential source code, or restricted information into an unapproved AI assistant.

Code review

Production changes should follow peer review, automated testing, and the approved release process. Do not include secrets or sensitive data in logs or test fixtures.

Practical reminder

If the situation is unclear, consult the appropriate policy owner rather than assuming an exception or inventing a rule.

9. Incident Response and Reporting

What counts as an incident

A security incident may include suspected account compromise, malware, lost equipment, accidental disclosure, unauthorized access, exposed credentials, or unusual system behavior.

First actions

Report promptly to IT Security or the Service Desk. Preserve relevant messages and timestamps when safe. Do not delete evidence or investigate beyond your authorization.

Containment

Follow response-team instructions. They may ask you to disconnect a device, change credentials, revoke sessions, or stop using an application. Do not wipe a device unless instructed, except where immediate safety requires it.

After the incident

Provide accurate information and cooperate with the review. The response team will assess impact, contain the issue, restore service, and identify improvements.

Practical reminder

If the situation is unclear, consult the appropriate policy owner rather than assuming an exception or inventing a rule.

10. Quick Reference and FAQs

How often must passwords be changed?

Every 90 days under this sample policy, and immediately if compromise is suspected or IT Security instructs a change.

Is MFA required?

Yes, for remote access, administrative actions, and supported company applications. Never approve a prompt you did not initiate.

Can I put an API key directly in Python code?

No. Store it in approved secret management or protected environment configuration. Keep `.env` files out of Git.

What should I do after clicking a phishing link?

Report it immediately to IT Security, especially if you entered credentials, opened a file, or approved an unexpected MFA prompt.

Can I upload company documents to any AI tool?

No. Use only AI services approved for the information's classification. Do not upload confidential or restricted data to an unapproved service.

Where should I report a lost laptop?

Immediately contact the IT Service Desk and your manager through verified reporting channels.

Practical reminder

If the situation is unclear, consult the appropriate policy owner rather than assuming an exception or inventing a rule.